Práctica 1: Recogida de información pasiva

Técnicas de Hacking - Universidad Europea

Estudiante: Gonzalo Revuelta

Objetivo: Auditoría OSINT Repsol S.A.

Índice

1. Investigación de Registros DNS (1.0 pt) **2**

1.1. Función de los registros 2

1.2. Metodología: ¿Cuándo es Pasivo o Activo? 2

2. Auditoría OSINT: Repsol S.A. (4.0 pts) **2**

2.1. Fase 1: Perfilado y Modelo de Negocio (2.1) 2

2.2. Fase 2: El hilo conductor DNS - De la teoría a la práctica 2

2.3. Fase 3: Mapeo de la superficie y subdominios 3

2.4. Fase 4: Google Dorking - Buscando el error humano (0.5 pts) 3

3. Conclusiones y Cumplimiento Ético **5**

Bibliografía **6**

1. Investigación de Registros DNS (1.0 pt)

Como base técnica antes de iniciar la auditoría, es fundamental entender el papel del DNS.

1.1. Función de los registros

Para mapear la infraestructura de Repsol, primero debemos comprender qué información nos da cada registro:

- A / AAAA: Direcciones IP (v4 y v6) de sus servidores frontales.
- MX: Servidores de correo. Es el primer punto donde detectamos proveedores externos.
- TXT: Crucial para ver registros SPF/DMARC y validar la seguridad contra suplantación.
- CNAME / NS / SOA / PTR: Registros que definen alias, autoridad y resolución inversa de la infraestructura.

1.2. Metodología: ¿Cuándo es Pasivo o Activo?

En esta práctica, mi enfoque ha sido estrictamente pasivo. He utilizado herramientas que consultan bases de datos preexistentes. Si hubiera lanzado un comando de transferencia de zona (AXFR) directamente contra los servidores NS de Repsol, la auditoría pasaría a ser activa, lo cual está prohibido en este escenario según el aviso legal.

2. Auditoría OSINT: Repsol S.A. (4.0 pts)

2.1. Fase 1: Perfilado y Modelo de Negocio (2.1)

Mi investigación comenzó analizando a qué se dedica Repsol. No podemos atacar lo que no entendemos. Descubrí que es una empresa multienergética que sirve a millones de clientes (particulares y aviación) y depende de proveedores críticos como Microsoft para su operativa diaria.

Este primer paso me dio la clave: al ser una empresa tan grande y moderna, su superficie de ataque no estaría en servidores físicos propios, sino probablemente en la nube.

2.2. Fase 2: El hilo conductor DNS - De la teoría a la práctica

Con la sospecha de que usaban la nube, utilicé **DNSDumpster** para confirmar mi teoría. Al analizar los registros MX, el resultado fue claro: todo el tráfico de correo pasa por `mail.protection.outlook.com`.

Esto me llevó a la siguiente conclusión: Repsol confía su identidad digital a Microsoft Azure. Por tanto, mi siguiente paso lógico fue buscar dónde se loguean sus empleados.

Host	IP	ASN	ASN Name	Open Services (from DB)	RevIP	
repsol-com.mail.protection.outlook.com	52.101.73.1 mail-am3pr04cu00501.inbound.protection.outlook.com	ASN: 8075 52.96.0.0/12	MICROSOFT-CORP-MSN-AS-BLOCK - Microsoft Corporation The Netherlands		56452	⋮
repsol-com.mail.protection.outlook.com	52.101.68.36 mail-db5pr02cu00104.inbound.protection.outlook.com	ASN: 8075 52.96.0.0/12	MICROSOFT-CORP-MSN-AS-BLOCK - Microsoft Corporation Ireland		56504	⋮
repsol-com.mail.protection.outlook.com	52.101.68.39 mail-db7pr03cu00607.inbound.protection.outlook.com	ASN: 8075 52.96.0.0/12	MICROSOFT-CORP-MSN-AS-BLOCK - Microsoft Corporation Ireland		56385	⋮
repsol-com.mail.protection.outlook.com	52.101.73.15	ASN: 8075 52.96.0.0/12	MICROSOFT-CORP-MSN-AS-BLOCK - Microsoft Corporation The Netherlands		56280	⋮

Figura 1: Hallazgo clave: Los registros MX confirman la dependencia de servicios Office 365.

2.3. Fase 3: Mapeo de la superficie y subdominios

Siguiendo el rastro de la infraestructura, generé un mapa de subdominios. Al ver la inmensa cantidad de activos, comprendí que la empresa tiene portales específicos para cada tipo de cliente (industrial, particular, comercial). Esto aumenta exponencialmente las posibilidades de encontrar un descuido humano.

Figura 2: Grafo de infraestructura: La complejidad de la red de Repsol facilita la existencia de activos olvidados.

2.4. Fase 4: Google Dorking - Buscando el error humano (0.5 pts)

Tras mapear los servidores y ver que Repsol usa infraestructuras híbridas, decidí usar Google como un «escáner pasivo». Mi estrategia no fue lanzar dorks al azar, sino seguir un hilo de investigación:

1. Fuga de documentación interna: Primero, busqué si había documentos que no deberían estar indexados. Al usar `filetype:pdf "confidencial"`, el objetivo era encontrar manuales o normativas que revelen cómo se organizan internamente.

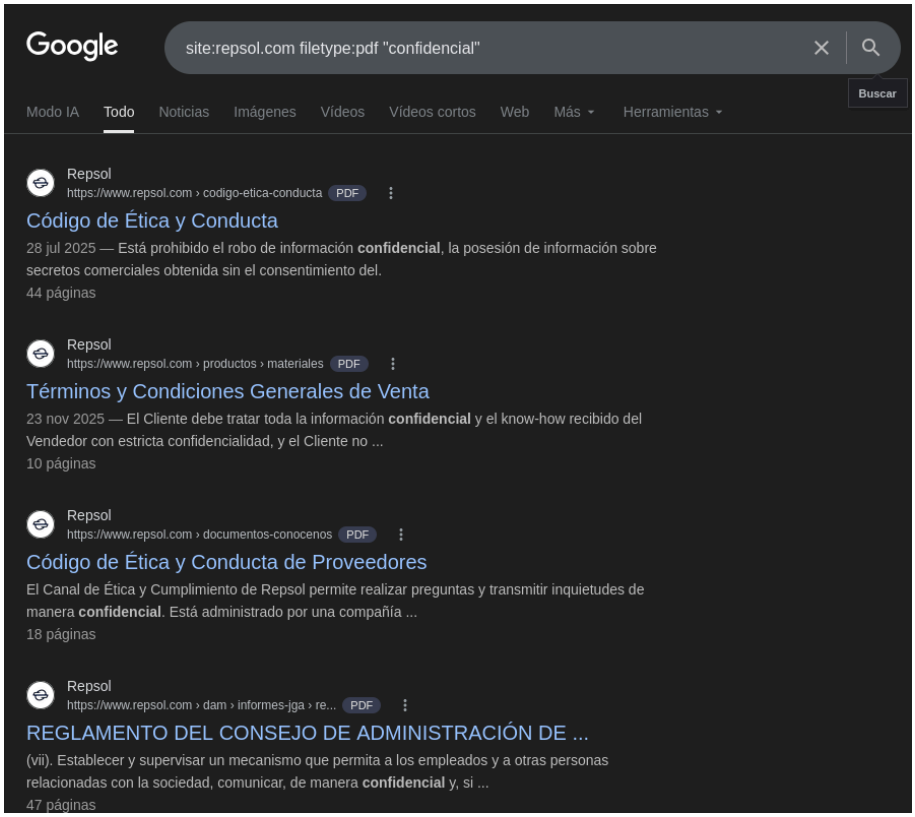

Figura 3: Dork 1: Localización de archivos PDF con posibles fugas de información interna.

2. Exposición de portales de acceso: Como el DNS me confirmó que usan Microsoft y Azure, el siguiente paso lógico fue buscar sus puntos de entrada. Usé `inurl:login` para mapear qué portales de empleados están expuestos directamente a Internet, lo cual es oro para un ataque de ingeniería social.

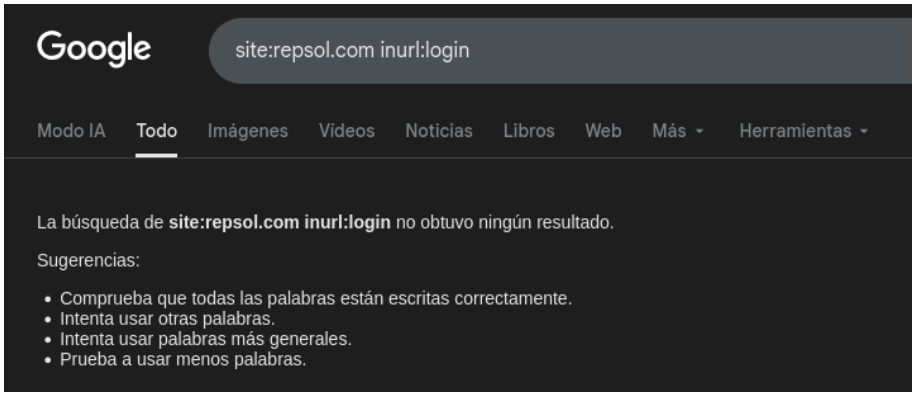

Figura 4: Dork 2: Identificación de portales de autenticación y paneles de acceso.

3. Fallos de configuración en servidores: Finalmente, quise comprobar si algún administrador olvidó cerrar el listado de directorios. El dork `intitle:"index of"` es la prueba definitiva de higiene digital. Encontrar un directorio abierto permitiría navegar por la estructura de archivos sin permiso.

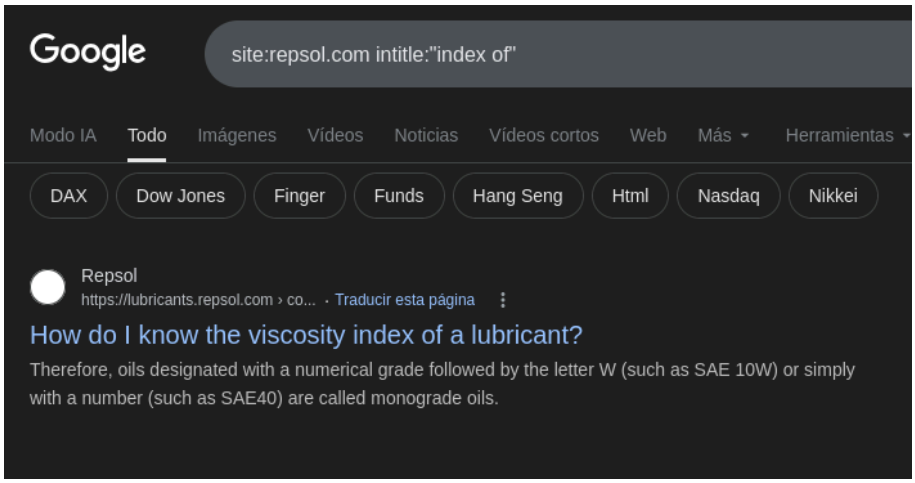

Figura 5: Dork 3: Verificación de servidores web con configuraciones de listado de archivos (Index of).

3. Conclusiones y Cumplimiento Ético

La «historia» de esta auditoría demuestra que el OSINT es una cadena: el modelo de negocio me llevó al DNS, el DNS me confirmó el uso de la nube de Microsoft, y eso me dirigió a buscar portales de acceso y documentos sensibles. Todo el proceso se ha realizado de forma 100% pasiva, cumpliendo con el aviso legal de la práctica y sin interactuar con los sistemas de defensa de Repsol S.A.

Bibliografía